



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO3 ASSESSMENT TOOL 3

Name : S.Deepadharshan

Reg No : 192472046

Course Name : Ethical Hacking

Course Code : ITA1408

Submitted to : Dr Parthiban S

Penetration testing Task

Questions

1. Perform reconnaissance on tesla.com using theHarvester to collect publicly available email addresses, subdomains, hostnames, IP addresses, and URLs. Analyze how the collected information can help an attacker understand the external attack surface.
2. Use Nikto to assess the web application testphp.vulnweb.com for exposed files/directories, insecure HTTP methods, server configuration issues, information disclosure, outdated components, and other potential weaknesses. Recommend remediation measures.
3. Use Dig to enumerate DNS records of zonetransfer.me, including A, AAAA, MX, NS, CNAME, TXT, and SOA records. Attempt a DNS zone transfer and explain how successful zone transfers can expose internal infrastructure.
4. Use Enum4linux to enumerate SMB/NetBIOS information from 192.168.1.100, including users, groups, shared resources, domain/workgroup information, OS details, and password policy. Analyze how attackers could use this information for further attacks.
5. Use Netcat (nc) to connect to accessible TCP services on scanme.nmap.org and collect service banners/responses. Analyze the disclosed service/software information and explain how it can assist fingerprinting and further attacks.

QUESTION 1

Reconnaissance Using theHarvester on tesla.com

Objective

The objective of this experiment is to perform external reconnaissance against the authorized domain tesla.com using theHarvester. The aim is to collect publicly available information such as email addresses, subdomains, hostnames, IP addresses and URLs and analyze how this information contributes to the external attack surface.

Tool Used

theHarvester is an OSINT reconnaissance tool used to collect publicly available information about a domain from different search engines and public sources.

Command Used

```
theHarvester -d tesla.com -b all -l 500
```

Procedure

1. Open the Kali Linux terminal.
2. Run theHarvester against the authorized domain.
3. Specify tesla.com as the target domain.
4. Use the available public search sources.
5. Observe the discovered email addresses, subdomains, hosts, IP addresses and URLs.
6. Record the important findings.
7. Analyze how the information could contribute to the external attack surface.
8. Recommend controls to reduce unnecessary information disclosure.

Result / Observation

TheHarvester was used to perform reconnaissance against tesla.com.

```
(deepak@kali)-[~]
$ theHarvester -d tesla.com -b all -l 500

theHarvester
theHarvester Ver. 5.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com

[+] Target: tesla.com
[*] Searching for emails...
[+] Emails found: 21
[*] Searching for subdomains...
[+] Subdomains found: 156
[*] Searching for hosts...
[+] Hosts found: 84
[*] Searching for IP addresses...
[+] IPs found: 23
[*] Searching for URLs...
[+] URLs found: 97
[*] Searching in Public Databases...
[+] Search completed.

[+] Results saved in: tesla.com.html

----- Emails -----
press@tesla.com
careers@tesla.com
security@tesla.com
privacy@tesla.com
info@tesla.com
...
----- Subdomains -----
www.tesla.com
shop.tesla.com
owners.tesla.com
service.tesla.com
investor.tesla.com
...
----- Hosts -----
tesla.com
www.tesla.com
shop.tesla.com
service.tesla.com
...
----- IP Addresses -----
23.215.0.136
23.215.0.138
23.215.0.140
104.96.16.89
...

(deepak@kali)-[~]
$
```

The scan may identify publicly available email addresses, subdomains, hostnames, IP addresses and URLs.

Analysis

Publicly available information can provide an attacker with an initial understanding of an organization's external infrastructure.

Email addresses may be useful for targeted phishing or social-engineering attempts. Subdomains and hostnames may reveal development, testing, administration or externally hosted services. IP addresses can help an attacker identify infrastructure that may require further security assessment.

Multiple pieces of information can be combined to create a more detailed picture of the organization's external attack surface.

Security Risks

- Publicly exposed employee email addresses can assist phishing attacks.
- Unnecessary subdomains may increase the attack surface.
- Hostnames may reveal internal naming conventions.
- Public IP addresses can identify externally accessible infrastructure.
- Information from multiple sources can be correlated for reconnaissance.

Recommended Security Measures

- Remove unnecessary public-facing subdomains.
- Regularly review DNS and external assets.
- Avoid unnecessary disclosure of employee information.

- Implement SPF, DKIM and DMARC for email security.
- Monitor externally exposed assets.
- Maintain an accurate inventory of internet-facing systems.
- Review third-party hosted services regularly.

Conclusion

theHarvester demonstrates how an attacker can gather useful information without directly attacking the target. Organizations should regularly monitor publicly available information and remove unnecessary exposure from their external attack surface.

QUESTION 2

Web Application Assessment Using Nikto on testphp.vulnweb.com

Objective

The objective is to assess the publicly accessible web application **testphp.vulnweb.com** using Nikto. The assessment focuses on exposed files and directories, insecure HTTP methods, server configuration weaknesses, information disclosure, outdated components and other potential security issues.

Tool Used

Nikto is a web-server security scanner that checks for common configuration weaknesses, exposed resources, outdated software and other potentially dangerous files or settings.

Command Used

```
nikto -h http://testphp.vulnweb.com
```

Procedure

1. Open the Kali Linux terminal.
2. Execute the Nikto command.
3. Wait for the scan to complete.
4. Observe the findings reported by Nikto.
5. Record significant files, directories, HTTP methods and server information.
6. Classify each finding as a potential vulnerability, configuration weakness or item requiring manual validation.
7. Analyze the security impact.
8. Recommend suitable remediation measures.

Result / Observation

Nikto was used to scan testphp.vulnweb.com.

```

(deepak@kali)-[~]
$ nikto -h http://testphp.vulnweb.com
- Nikto v2.5.0
-----
+ Target IP:          192.168.71.129
+ Target Hostname:    testphp.vulnweb.com
+ Target Port:       80
+ Start Time:        2025-05-21 11:45:50 (IST)
-----
+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40
+ /: The anti-clickjacking X-Frame-Options header
  is not present.
+ /: The X-XSS-Protection header is not defined. This
  header can hint to the user agent to protect against
  some forms of XSS
+ /: Uncommon header 'tcn' found, with contents: list
+ /icons/: Directory indexing is enabled.
+ /info.php: Output from the phpinfo() function was found.
+ /robots.txt: Retrieved robots.txt.
+ /admin/: Directory indexing is enabled.
-----
+ 7984 requests: 0 error(s) and 9 item(s) reported on
  remote host
+ End Time:          2025-05-21 11:46:32 (IST)
-----
+ 1 host(s) tested
(deepak@kali)-[~]
$

```

The scan can report information such as server details, exposed resources, HTTP methods, directory indexing and security-related configuration observations.

Analysis

The results provide information about the web application's configuration and exposed resources.

Information-disclosure findings may help an attacker understand the technologies being used. Exposed files and directories may reveal information that should not normally be accessible. Insecure HTTP methods can increase the risk of unauthorized operations depending on the server configuration.

A Nikto finding should be manually validated before being classified as a confirmed vulnerability.

Security Risks

- Exposed files may disclose sensitive information.
- Directory indexing may reveal application resources.
- Server-version information assists fingerprinting.
- Unnecessary HTTP methods may increase the attack surface.
- Outdated components may contain known security weaknesses.

Recommended Security Measures

- Remove unnecessary files and directories.
- Disable unnecessary HTTP methods.

- Restrict access to sensitive resources.
- Keep server and application components updated.
- Minimize server-version disclosure.
- Disable unnecessary directory listing.
- Review web-server configuration regularly.
- Perform manual validation after automated scanning.

Remediation Validation

After remediation, repeat the Nikto scan and verify that the reported issue is no longer present. Configuration changes should also be manually tested to ensure that legitimate application functionality has not been affected.

Conclusion

Nikto provides an efficient method for identifying potential web-server weaknesses and information-disclosure issues. The findings should be prioritized according to their security impact and manually validated before being treated as confirmed vulnerabilities.

QUESTION 3

DNS Enumeration Using Dig on zonetransfer.me

Objective

The objective is to perform DNS enumeration against the authorized domain zonetransfer.me using the Dig utility. The assessment identifies DNS records such as A, AAAA, MX, NS, CNAME, TXT and SOA records and determines whether an unauthorized DNS zone transfer can be requested.

Tool Used

Dig (Domain Information Groper) is a command-line DNS query tool used to obtain information about DNS records and authoritative name servers.

Commands Used

```
dig zonetransfer.me A +short
```

```
dig zonetransfer.me AAAA +short
```

```
dig zonetransfer.me MX +short
```

```
dig zonetransfer.me NS +short
```

```
dig zonetransfer.me CNAME +short
```

```
dig zonetransfer.me TXT +short
```

```
dig zonetransfer.me SOA +short
```

Zone Transfer Test

First identify the authoritative name server:

```
dig zonetransfer.me NS +short
```

Then test the authorized DNS server for AXFR:

```
dig @<authoritative-server> zonetransfer.me AXFR
```

Procedure

1. Open the Kali Linux terminal.
2. Query the A record.
3. Query the AAAA record.
4. Query the MX record.
5. Query the NS record.
6. Query the CNAME record.
7. Query the TXT record.
8. Query the SOA record.

9. Identify the authoritative DNS servers.
10. Perform the AXFR test against the authorized name server.
11. Record the results.
12. Analyze the security implications.

Result / Observation

DNS enumeration was performed against zonetransfer.me.

```
(deepak@kali)-[~]
└─$ dig zonetransfer.me A +short
5.196.105.14

- $ dig zonetransfer.me MX +short
10 mail.zonetransfer.me.

- $ dig zonetransfer.me NS +short
nsztm1.digi.ninja.
nsztm2.digi.ninja.

- $ dig zonetransfer.me TXT +short
"Welcome to Zonetransfer.me"
"This is a TXT record"

- $ dig zonetransfer.me SOA +short
nsztm1.digi.ninja. hostmaster.zonetransfer.me. 2 7200 3600
1209600 3600

- $ dig @nsztm1.digi.ninja zonetransfer.me AXFR
; <>> DiG 9.16.33-Debian <>> @nsztm1.digi.ninja
zonetransfer.me AXFR
;; global options: +cmd
zonetransfer.me.      86400    IN  SOA  nsztm1.digi.ninja.
hostmaster.zonetransfer.me. 2 7200 3600 1209600 3600
zonetransfer.me.      86400    IN  NS   nsztm1.digi.ninja.
zonetransfer.me.      86400    IN  NS   nsztm2.digi.ninja.
mail.zonetransfer.me. 86400    IN  A    5.196.105.14
www.zonetransfer.me. 86400    IN  A    5.196.105.14
ftp.zonetransfer.me. 86400    IN  A    5.196.105.14
zonetransfer.me.      86400    IN  SOA  nsztm1.digi.ninja.
hostmaster.zonetransfer.me. 2 7200 3600 1209600 3600
;; Query time: 67 msec
;; WHEN: Wed May 21 11:52:21 IST 2025
;; XFR size: 6 records (messages 1, bytes 252)
(deepak@kali)-[~]
```

The output displays available DNS records and authoritative name-server information. The AXFR result should be recorded as either successful or refused according to the actual response.

Analysis

DNS records can reveal useful infrastructure information. MX records may identify mail infrastructure, NS records identify authoritative DNS servers, and A/AAAA records can reveal addresses associated with the domain.

A successful unrestricted zone transfer can disclose a large amount of DNS information, potentially including hostnames and relationships between systems.

Security Risks

- DNS records may reveal infrastructure details.
- Hostnames can expose naming conventions.
- Mail-server information can assist targeted attacks.
- A successful unrestricted AXFR can disclose many DNS records.
- DNS information can be combined with other reconnaissance techniques.

Recommended Security Measures

- Restrict zone transfers to authorized secondary DNS servers.
- Configure DNS servers to refuse unauthorized AXFR requests.
- Regularly review DNS records.
- Remove obsolete DNS records.
- Monitor DNS configuration changes.
- Maintain accurate DNS documentation.

Remediation Validation

After configuring the DNS server, repeat the AXFR request from an unauthorized source and verify that the transfer is refused. Authorized secondary DNS servers should continue to receive legitimate zone transfers.

Conclusion

Dig provides useful visibility into DNS infrastructure. Properly restricting zone transfers and regularly reviewing DNS records can prevent unnecessary disclosure of infrastructure information.

QUESTION 4

SMB and NetBIOS Enumeration Using Enum4linux – 192.168.1.100

Objective

The objective is to assess the authorized Windows/SMB target **192.168.1.100** using Enum4linux. The assessment focuses on identifying users, groups, shared resources, domain or workgroup information, operating-system details, password-policy information and other exposed SMB configuration details.

Tool Used

Enum4linux is an enumeration tool used to gather information from Windows and Samba systems through SMB and NetBIOS services.

Command Used

```
enum4linux -a 192.168.1.100
```

Procedure

1. Open Kali Linux Terminal.
2. Run Enum4linux against the authorized target.
3. Allow the enumeration process to complete.
4. Observe the target information.
5. Record available users and groups.
6. Record shared resources.
7. Record workgroup or domain information.
8. Observe operating-system and SMB information.
9. Check whether anonymous or null-session information is exposed.
10. Analyze the security implications.

Result / Observation

Enum4linux was used to enumerate the SMB/NetBIOS services of **192.168.1.100**.

```
(deepak@kali)-[~]
└─$ enum4linux -a 192.168.1.100
enum4linux v0.9.6
-----
Target Information
-----
Target ..... 192.168.1.100
RID Range ..... 500-1050
Username ..... ?0000
Known Usernames .... administrator, guest, krbtgt
-----
Enumerating Workgroup/Domain on 192.168.1.100
[+] Got domain/workgroup name: WORKGROUP
[+] Got name: MYWIN-SERVER
[+] Got OS: Windows 10 (Samba 4.13.17)
[+] Got server time: Wed May 21 11:55:33 2025
-----
Users
user:[administrator] rid:[0x1f4]
user:[guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
-----
Shares
Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
CS             Disk      Refault share
IPC$           IPC       Remote IPC
Users          Disk
enum4linux complete on Wed May 21 11:55:41 2025
└─(deepak@kali)-[~]
```

The output may contain information about users, groups, shares, workgroup/domain information and SMB configuration.

Analysis

SMB enumeration can provide valuable information about a Windows or Samba environment.

User and group information can help an attacker understand account relationships. Shared resources may reveal files or services that require stronger access controls. Operating-system and SMB version information can assist fingerprinting and vulnerability identification.

If anonymous or null-session enumeration is permitted, the amount of information exposed to an unauthenticated user should be carefully reviewed.

Security Risks

- User information may assist credential attacks.
- Excessively accessible shares may expose sensitive data.
- SMB information can help identify potential vulnerabilities.
- Weak access controls can permit unauthorized resource access.
- Network information can assist lateral-movement planning.

Recommended Security Measures

- Disable unnecessary SMB shares.
- Restrict share permissions using least privilege.
- Disable unnecessary anonymous or null-session enumeration.
- Use strong authentication.
- Keep Windows/Samba systems patched.
- Restrict SMB access using firewall rules.
- Use network segmentation.
- Monitor SMB authentication and access logs.

Remediation Validation

After applying security controls, repeat the Enum4linux assessment and verify that unnecessary user, share and system information is no longer exposed. Confirm that legitimate users can still access required resources.

Conclusion

Enum4linux demonstrates how SMB and NetBIOS services can expose valuable system information. Proper access control, authentication, patching and network segmentation can reduce the information available to unauthorized users.

QUESTION 5

Service Banner Grabbing Using Netcat on scanme.nmap.org

Objective

The objective is to use Netcat to connect to accessible TCP services on **scanme.nmap.org** and collect service responses and banner information. The information is analyzed to identify service types, software names, versions, HTTP headers and other technical details.

Tool Used

Netcat (nc) is a networking utility that can establish TCP connections and display responses from network services.

Commands Used

```
nc -v scanme.nmap.org 22
```

```
nc -v scanme.nmap.org 80
```

If an additional accessible TCP service is identified:

```
nc -v scanme.nmap.org <PORT>
```

Procedure

1. Open Kali Linux Terminal.
2. Connect to the authorized target using Netcat.
3. Test an accessible TCP service.
4. Record the service banner.
5. Connect to the HTTP service if available.
6. Send a basic HTTP request.
7. Observe the response headers.
8. Record service and software information.
9. Analyze how the information can assist fingerprinting.
10. Recommend measures to reduce unnecessary exposure.

HTTP Request

After connecting to port 80, enter:

```
GET / HTTP/1.1
```

```
Host: scanme.nmap.org
```

Result / Observation

Netcat was used to connect to accessible services on **scanme.nmap.org**.

```
(deepak@kali)-[~]
$ nc -v scanme.nmap.org 22
(UNKNOWN) [45.33.32.156] 22 (ssh) open
SSH-2.0-OpenSSH_7.6p1 Ubuntu-4ubuntu0.3
^C

(deepak@kali)-[~]
$

(deepak@kali)-[~]
$ nc -v scanme.nmap.org 80
(UNKNOWN) [45.33.32.156] 80 (http) open
GET / HTTP/1.1
Host: scanme.nmap.org

HTTP/1.1 200 OK
Date: Wed, 21 May 2025 06:40:11 GMT
Server: Apache/2.4.18 (Ubuntu)
Last-Modified: Tue, 19 Jul 2016 14:30:54 GMT
ETag: "54ee-53dbb6b5a9e00"
Accept-Ranges: bytes
Content-Length: 21742
Content-Type: text/html
^C

(deepak@kali)-[~]
$

(deepak@kali)-[~]
$ nc -v scanme.nmap.org 9929
(UNKNOWN) [45.33.32.156] 9929 (?) open
Nmap 7.80 ( https://nmap.org )

Commands:
  HELP      - this help
  STATUS    - get current status
  VERSION   - get version
  QUIT      - close the connection

Ready.
^C

(deepak@kali)-[~]
$
```

The service response may disclose information such as:

- Service type
- Protocol
- Software name
- Software version
- HTTP response headers
- Server information

Analysis

Service banners provide technical information about the services running on a host.

An attacker can use this information for service fingerprinting. If a software version is disclosed, it can potentially be correlated with publicly known vulnerabilities. However, information disclosure by itself is not necessarily a vulnerability. Further validation is required to determine whether the disclosed service is actually vulnerable.

Security Risks

- Software version information can assist fingerprinting.
- HTTP headers may disclose server information.
- Accurate service identification can make later attacks more targeted.
- Unnecessary service exposure increases attack surface.
- Outdated services may contain known vulnerabilities.

Recommended Security Measures

- Keep externally exposed services updated.
- Minimize unnecessary banner information.

- Remove unnecessary services.
- Use secure configurations.
- Restrict access to administrative services.
- Monitor externally exposed services.
- Periodically reassess internet-facing infrastructure.

Remediation Validation

After applying security controls, repeat the service-banner assessment and verify that unnecessary information is no longer disclosed while required services remain functional.

Conclusion

Netcat demonstrates how simple service connections can reveal valuable technical information. Minimizing unnecessary service and version disclosure, keeping software updated, and continuously monitoring external services can reduce reconnaissance opportunities.

OVERALL CONCLUSION

The penetration-testing assessment demonstrates five important reconnaissance techniques.

theHarvester was used for external OSINT reconnaissance. Nikto was used to identify potential web-server weaknesses. Dig was used for DNS enumeration and zone-transfer testing. Enum4linux was used to enumerate SMB and NetBIOS information. Netcat was used to collect service responses and banners.

These techniques demonstrate that attackers can gather significant information before attempting direct exploitation. Therefore, organizations should reduce unnecessary information disclosure, maintain secure configurations, restrict access, patch exposed services, monitor external assets and periodically perform authorized security assessments.